

Amélioration de la sécurité du service OpenSSH sur le serveur

GABIN

Floralyn

19/12/2025

09/01/2026 modification

Q30. Mettre en œuvre les préconisations suivantes tirées des recommandations pour un usage sécurisé de SSH publié par l'ANSSI :

1. Amélioration de la sécurité du service OpenSSH sur le serveur

1. Vérifier que les clés privées de chiffrement présentes dans le répertoire /etc/ssh/ appartiennent à l'utilisateur root en lecture-écriture seulement ;

Toutes les clés privées sont en 600, grâce à la commande **ls -l**

```
etusio@srvssh:~$ ls -l ~/.ssh/
total 16
-rw----- 1 etusio etusio 350 déc. 19 09:22 authorized_keys
-rw----- 1 etusio etusio 1823 nov. 28 10:04 id_rsa
-rw-r--r-- 1 etusio etusio 395 nov. 28 10:04 id_rsa.pub
-rw-r--r-- 1 etusio etusio 223 déc. 19 11:21 known_hosts
```

```
etusio@srvssh:~$ ls -l /etc/ssh/ssh_host_*_key
-rw----- 1 root root 505 mars 29 2020 /etc/ssh/ssh_host_ecdsa_key
-rw----- 1 root root 399 mars 29 2020 /etc/ssh/ssh_host_ed25519_key
-rw----- 1 root root 1823 mars 29 2020 /etc/ssh/ssh_host_rsa_key
```

2. S'assurer que c'est bien la version 2 du protocole SSH qui est utilisée ;

Version 2 du protocole SSH : Est bien mis en place

```
# Port 22
# Protocol 2
# Ciphers aes128-
```

3. **Le serveur SSH doit dorénavant écouter sur le port 222/TCP ;**
Le port étant à la prise 22, il suffit de modifier le nombre attribué par 222,

```
# Port 222_
```

4. **Vérifier que les droits sur les fichiers sont appliqués de manière stricte par SSH ;**

```
etusio@srvssh:~$ ls -l /etc/ssh/ssh_config
-rw-r--r-- 1 root root 1606 déc. 19 11:54 /etc/ssh/ssh_config
```

Premièrement, je pensais qu'il suffisait de vérifier que le fichier était bien en droit d'accès strict. Cependant une commande SSH permet de le faire systématiquement, ci-dessous :

StrictModes

Specifies whether [sshd\(8\)](#) should check file modes and ownership of the user's files and home directory before accepting login. This is normally desirable because novices sometimes accidentally leave their directory or files world-writable. The default is "yes". Note that this does not apply to **ChrootDirectory**, whose permissions and ownership are checked unconditionally.

```
# StrictModes yes
```

5. **L'accès SSH par l'utilisateur root doit être interdite ;**
N'est pas installé par défaut : j'écris la commande,

```
# PermitRootLogin no
```

PermitRootLogin

Specifies whether root can log in using [ssh\(1\)](#). The argument must be "yes", "prohibit-password", "without-password", "forced-commands-only", or "no". The default is "prohibit-password".

If this option is set to "prohibit-password" or "without-password", password and keyboard-interactive authentication are disabled for root.

If this option is set to "forced-commands-only", root login with public key authentication will be allowed, but only if the *command* option has been specified (which may be useful for taking remote backups even if root login is normally not allowed). All other authentication methods are disabled for root.

If this option is set to "no", root is not allowed to log in.

Cette commande ne permet pas au "root" (droit administrateur) de pouvoir se connecter dans son serveur

6. Mettre en œuvre une séparation des privilèges à l'aide d'un bac à sable (sandbox) ;

```
# UsePrivilegeSeparation
```

UsePrivilegeSeparation

Specifies whether [sshd\(8\)](#) separates privileges by creating an unprivileged child process to deal with incoming network traffic. After successful authentication, another process will be created that has the privilege of the authenticated user. The goal of privilege separation is to prevent privilege escalation by containing any corruption within the unprivileged processes. The argument must be "yes", "no", or "sandbox". If **UsePrivilegeSeparation** is set to "sandbox" then the pre-authentication unprivileged process is subject to additional restrictions. The default is "sandbox".

UsePrivilegeSeparation (par défaut sandbox) : Enlève les privilèges (lecture, écriture, exécution) de tout hôte se connectant à son serveur, il n'a le droit à aucune droit administrateur

7. L'accès à distance par des comptes ne disposant pas de mot de passe doit être interdit ;

La commande **PermitEmptyPasswords no**

PermitEmptyPasswords

When password authentication is allowed, it specifies whether the server allows login to accounts with empty password strings. The default is "no".

Si un usager souhaite se connecter et qu'il n'a pas de mot de passe (l'espace est vide) le serveur automatiquement doit refuser la requête de l'hôte.

8. Autoriser 3 tentatives de connexion successives en cas d'erreur dans le mot de passe ;

Le nombre d'essai d'entrer de mot de passe doit être de 3 maximum, La commande n'était pas définie par défaut. Il faut l'implémenter par :

MaxAuth Tries 3

```
# MaxAuth Tries 3
```

MaxAuthTries

Specifies the maximum number of authentication attempts permitted per connection. Once the number of failures reaches half this value, additional failures are logged. The default is 6.

9. Le service doit afficher les informations de dernière connexion à l'utilisateur quand il se connecté ;

Cette commande permet d'**afficher** (print) la date et le temps de la **dernière connexion** (lastlog) de l'hôte : **PrintLastlog yes**

```
# PrintLastLog yes_
```

See also [ListenAddress](#).

PrintLastLog

Specifies whether [sshd\(8\)](#) should print the date and time of the last user login when a user logs in interactively. The default is "yes".

10. N'autoriser que l'utilisateur etusio à se connecter sur le serveur.

La commande **AllowUsers** permet donner l'autorisation à la connexion au serveur, et on spécifie par le groupe d'utilisateur : **etusio**

```
# AllowUsers etusio_
```

AllowUsers

This keyword can be followed by a list of user name patterns, separated by spaces. If specified, login is allowed only for user names that match one of the patterns. Only user names are valid; a numerical user ID is not recognized. By default, login is allowed for all users. If the pattern takes the form USER@HOST then USER and HOST are separately checked, restricting logins to particular users from particular hosts. HOST criteria may additionally contain addresses to match in CIDR address/masklen format. The allow/deny directives are processed in the following order: **DenyUsers**, **AllowUsers**, **DenyGroups**, and finally **AllowGroups**.

See PATTERNS in [ssh_config\(5\)](#) for more information on patterns.

Seulement le groupe spécifiant dans celui de etusio pourra avoir l'autorisation de se connecter au serveur